SECAI+ LESSON 6.3.2

Important AI Compliance Frameworks

A tour of the major legal, intergovernmental, and standards-based frameworks shaping responsible AI from binding EU law to voluntary best-practice guides.

- EU AI Act
- OECD Principles
- ISO/IEC Standards
- NIST AI RMF

EU AI ACT

The World's First Binding AI Law

Key Dates

August 1, 2024

Act enters into force

August 2, 2026

Most obligations take effect

What It Does

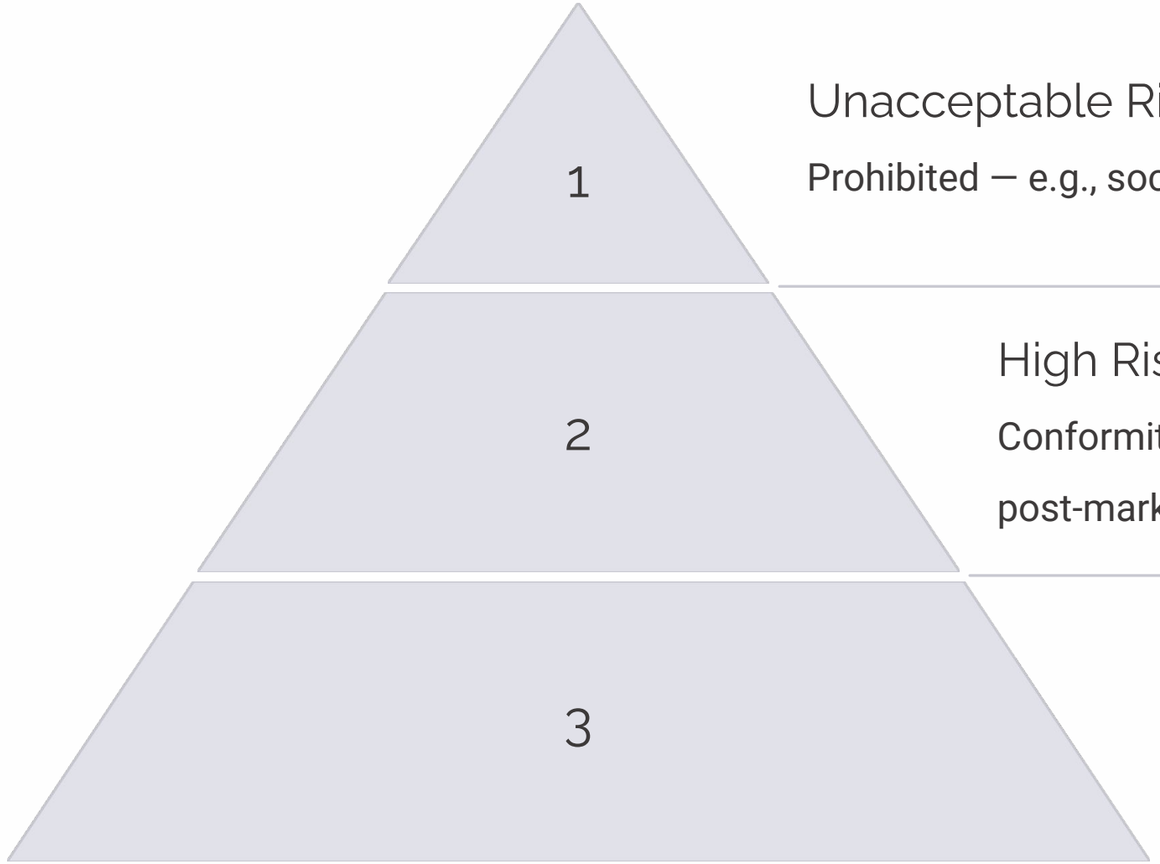
- Applies to all EU Member States
- Risk-based regulatory structure

Shifts AI governance from **best practice → legal requirement**

- Steep financial penalties for noncompliance

EU AI ACT

Three-Tier Risk Framework



Unacceptable Risk

Prohibited — e.g., social scoring systems

High Risk

Conformity, documentation, data management, testing, governance, post-market monitoring

Limited Risk

Transparency rules — disclose AI interaction, label synthetic media

Higher risk = heavier compliance burden. Organizations must classify their AI systems before deployment.

OECD AI PRINCIPLES

Intergovernmental Ethical Guidance

First adopted **2019**, updated **2024** not legally binding, but a globally influential reference for national strategies and corporate ethics programs.

Inclusive Growth

AI should benefit all of society

Human Rights & Democracy

Respect fundamental rights and values

Transparency & Explainability

AI decisions must be understandable

Robustness & Safety

Reliable, secure, and resilient systems

Accountability

Clear responsibility for AI outcomes

ISO/IEC STANDARDS

A Suite of Certifiable AI Standards

ISO/IEC standards provide **technical, certifiable frameworks** for managing AI responsibly across its full lifecycle.

ISO/IEC 42001:2023

AI Management System (AIMS) — policy, roles, risk management, lifecycle controls, continuous improvement. Certifiable via third-party audit.

ISO/IEC 23894:2023

AI Risk Management — integrate AI risks into enterprise programs; covers assessment, treatment, and monitoring.

ISO/IEC 22989:2022

Concepts & Terminology — shared language for model, training data, bias, and more.

ISO/IEC 5338:2023

AI System Lifecycle — addresses concept drift, model decay, and ongoing monitoring.

NIST AI RMF

NIST AI Risk Management Framework

A **voluntary, widely adopted** framework praised globally for its practicality. Structured around four core functions.

Adopted well beyond the U.S. by organizations seeking a practical AI risk management structure.

Govern

Culture, policies, accountability

Map

Identify risks in context

Measure

Analyze and assess risk levels

Manage

Prioritize, respond, and monitor

COMPARISON

Framework at a Glance

Framework	EU AI Act	OECD Principles	ISO/IEC Standards	NIST AI RMF
Legally Binding?	✅ Yes	❌ No	❌ No	❌ No
Certifiable?	Partially	❌ No	✅ Yes (42001)	❌ No
Scope	EU Market	Global	Global	Global
Primary Focus	Risk tiers & penalties	Ethical principles	Technical governance	Risk management

Most mature organizations layer multiple frameworks using NIST or ISO standards operationally while aligning to EU law for legal compliance.

Key Takeaways

1 **The EU AI Act is binding law**

Risk-based tiers with real penalties — prohibited, high-risk, and limited-risk categories. Most obligations apply from August 2026.

2 **OECD Principles set the ethical baseline**

Not legally enforceable, but widely referenced in national strategies and corporate ethics reviews worldwide.

3 **ISO/IEC standards enable certification**

42001 (AIMS), 23894 (risk), 22989 (terminology), and 5338 (lifecycle) — a comprehensive technical toolkit for AI governance.

4 **NIST AI RMF: Govern, Map, Measure, Manage**

Voluntary but globally adopted — a practical four-function model for operationalizing AI risk management.